

보안·데이터 정책을 P0 제품 Gate로 고정

위협 모델 → 분류·보존 → RAG 안전 Gate

결과: 18개 위협과 28개 통제로 잔여 위험을 중간 이하로 낮췄습니다

P0 정책 기준을 코드로 고정하고 12개 자동 검증으로 회귀를 차단했습니다.

위협 모델

18 Threats
28 Controls
Residual ≤ 9

데이터 정책

4 Classes
18 Retention Rules
Deletion $\leq 7d$

검증 결과

12/12 PASS | Secrets 0 | Epic #3 Ready for Approval

위협·통제·데이터 정책을 세 계층으로 고정했습니다

Activepieces는 실행하고 TechFlow가 정책·권한·상태·증적을 소유합니다.

01

Threat Model

18 threats
Likelihood × Impact
Residual ≤ 9

02

Data Policy

D0-D3
18 retention rules
Deletion ledger

03

RAG Gate

D0 default
D1 conditional
D2-D3 denied

정책 Gate | 분류 → 보존 → 삭제 → 감사 증적

데이터 등급과 보존·RAG 허용 범위를 기계적으로 고정했습니다

원문 Webhook과 Secret은 저장하지 않고, AI 원문은 명시적 opt-in만 최대 30일입니다.

분류 / 자산	예시	보존	RAG
D0 Public	공개 제품 문서	원본 수명	허용
D1 Internal	승인된 내부 지식	최대 365일	조건부
D2 Confidential	지원·고객 정보	업무별 180일	금지
D3 Restricted	Secret·Token	0일	금지
Webhook Raw	서명 포함 원문	0일	해당 없음
Audit	변경·승인 증적	365일	해당 없음
Backup	일간 / 주간	7 / 30일	해당 없음
AI Raw	명시적 opt-in	최대 30일	해당 없음

분류와 보존은 수집 전에 결정하며 삭제 증적은 ledger로 남깁니다.

정책 변경은 분류부터 삭제까지 여섯 Gate로 통제합니다

각 Gate는 소유자·승인·검증 결과가 있어야 다음 단계로 이동합니다.

A

Classify

D0-D3

Data Owner

B

Minimize

Raw 0d

Ingress

C

Approve

D1 Conditional

Provider

D

Execute

Least Privilege

Activepieces

E

Retain

Audit Ledger

Policy Job

F

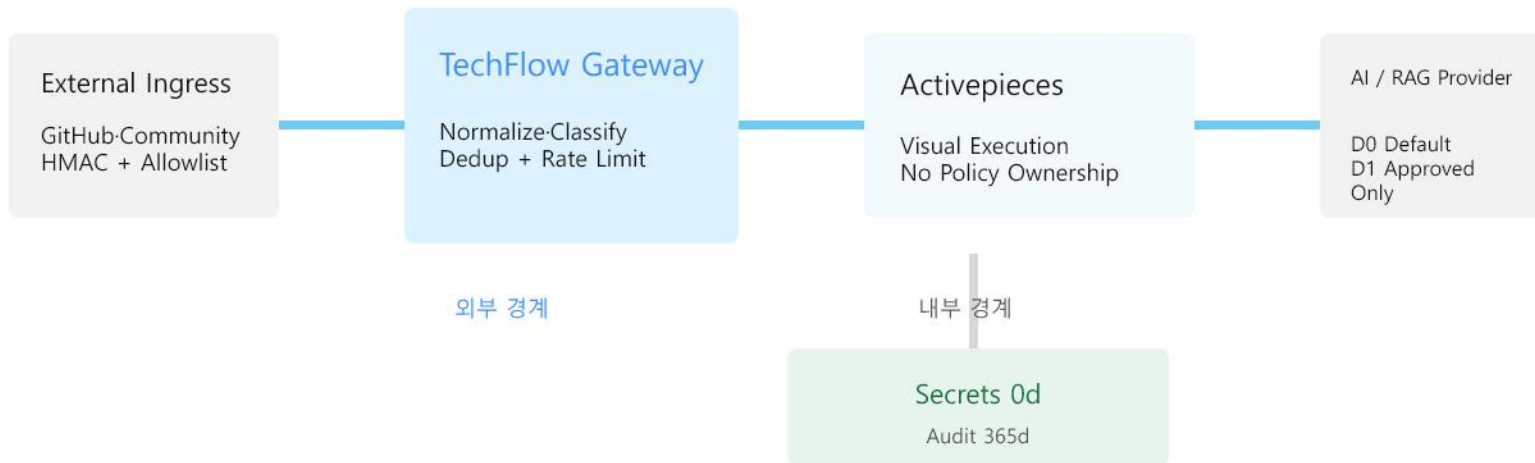
Delete

≤ 7 Days

Source·Chunk·Vector

외부 입력부터 AI Provider까지 신뢰 경계를 명시했습니다

정책 판정은 실행 엔진 밖에서 완료하고, 외부 전송은 분류 Gate를 통과해야 합니다.



제품 Gate와 회귀 검증이 모두 통과했습니다

T01-0
6

Webhook·권한

위조·재전송
SSRF·Secret
권한 상승
공급망

T07-1
8

운영·AI

Flow 우회·로그 유출
Prompt Injection
지식 오염·과도한 자율성

P0 Gate

자동 검증

Schema Valid
18 Threats
28 Controls
12/12 PASS
Residual ≤ 9

Threats

Controls

Policy PASS

정책·운영·증적을 하나의 제품 자산으로 묶었습니다

다음 단계의 RAG·업무 자동화도 같은 정책 계약으로 검토할 수 있습니다.

정책 자산

ADR-0006 Threat Model
ADR-0007 Data Policy
Policy JSON

운영 자산

Governance Runbook
RAG Gate
Deletion Procedure

검증 증거

12 Unit Tests
Report PDF · PPTX
Artifact Manifest

P0 기준 | Secrets 미저장 · Raw 0d · 삭제 7d · 감사 365d

사고는 탐지·분류·격리·복구 순서로 처리합니다

삭제 요청과 정책 위반도 동일한 증적·재검증 절차를 적용합니다.



완료 기준 = 잔여 위험 ≤ 9 + 삭제 ledger + 재검증 PASS

최종 결과

P0 보안·데이터 기준을
제품 Gate로 확정했습니다.

EPIC #3

READY FOR PRODUCT OWNER APPROVAL · 18 THREATS · 28 CONTROLS · 12/12 PASS